UNIT 1 · TOPIC 1.1

Social Engineering

Quiz

Instructions: This quiz has 18 multiple-choice questions, 1 point each. Circle the letter of the single best answer for each question.

Name: **Date:** **Class:**

1. A teacher receives an email from "do-not-reply@g00gle.com" asking them to click a link to approve a student's document-access request. Which detail is the strongest indicator that this message is a phishing attempt?

- ○ A. The email mentions a student by relationship rather than by name
- ○ B. The sender domain "g00gle.com" substitutes zeros for the letter O in "google"
- ○ C. The email was sent during school hours
- ○ D. The subject line uses an exclamation point

2. An attacker calls an employee, claims to be from the IT helpdesk, and references the employee's manager by name before asking for a password reset. Which social engineering tactic is this?

- ○ A. Pretexting
- ○ B. Tailgating
- ○ C. Baiting
- ○ D. Phishing

3. A worker badges into a secure office building, holding the door open for a person carrying boxes who has no visible ID badge. What social engineering risk does this scenario illustrate?

- ○ A. Quid pro quo
- ○ B. Vishing
- ○ C. Whaling
- ○ D. Tailgating

4. In the phishing email scenario, the message states: "Research shows that the faster teachers respond to students' document-sharing requests, the more likely students are to submit assignments on time." Why does this sentence make the email more persuasive?

- ○ A. It explains the technical steps required to share a document
- ○ B. It proves the sender is affiliated with an educational research organization
- ○ C. It cites a believable-sounding justification that pressures the teacher to act quickly without verifying the request
- ○ D. It confirms the student's identity to the teacher

5. An attacker leaves a USB drive labeled "Q4 Salary Review, Confidential" in an office break room. Why is this tactic likely to succeed in getting an employee to plug it in?

- ○ A. It requires the employee to enter a password before the attack works
- ○ B. It directly exploits a software vulnerability without any user action
- ○ C. It relies on the employee already trusting the attacker personally
- ○ D. It exploits curiosity and the perceived value of confidential information to override caution

6. If the teacher in the scenario had clicked the link and entered their school login credentials on the resulting page, what is the most likely organizational impact?

- ○ A. The teacher's device is permanently disconnected from the network
- ○ B. The school's email server automatically resets all passwords
- ○ C. The attacker gains access to the teacher's account and any systems or data it can reach
- ○ D. No impact occurs unless the teacher also opens an attachment

7. A school IT administrator is documenting the phishing incident with the teacher's email for a post-incident report. Which combination of evidence most strongly supports classifying this as a targeted phishing attempt rather than generic spam?

- ○ A. The email contained no links and only requested a reply
- ○ B. The email was sent to one teacher and used formal language
- ○ C. The email used a spoofed lookalike domain, referenced a plausible school workflow (document sharing), and created urgency tied to student outcomes
- ○ D. The email was flagged by the spam filter before the teacher saw it

8. A security awareness trainer is choosing which influence principle to emphasize when teaching staff to resist pretexting calls that impersonate IT support and reference real employee names. Which principle should be prioritized, and why?

- ○ A. Scarcity, the call implies a limited-time offer the target doesn't want to miss
- ○ B. Authority, attackers borrow the credibility of a trusted role (IT) combined with insider-sounding detail to suppress the target's instinct to verify
- ○ C. Liking, the attacker spends time building a personal friendship before asking for anything
- ○ D. Social proof, the attacker claims many other employees have already complied

9. A district is updating its incident-response checklist after several tailgating and pretexting incidents. Which checklist addition would most directly reduce risk across both attack types, given that they exploit different channels (physical vs. verbal)?

- ○ A. A monthly password rotation policy
- ○ B. A stronger spam filter on the email gateway
- ○ C. Mandatory multi-factor authentication on all cloud accounts
- ○ D. A policy requiring independent verification of any unscheduled request for access or information, regardless of how it arrives

10. A company wants receiving mail servers to reject any message that shows the company's domain in the visible From: line but fails sender authentication for that domain. Which DNS-published control does this?

- ○ A. An SPF record on its own
- ○ B. A DKIM public-key record
- ○ C. A DMARC record with the policy p=reject
- ○ D. An MX record

11. An employee is tricked into typing their password and second-factor code into a convincing fake login page that passes everything to the real site in real time. Which kind of multi-factor authentication would still have kept the attacker out?

- ○ A. A FIDO2/WebAuthn security key or passkey registered to the real site's domain
- ○ B. A six-digit code from an authenticator app
- ○ C. A one-time code sent by text message

○ D. Security questions about the employee's first school

12. A finance clerk receives an email from a long-standing supplier asking that next week's payment go to a new bank account "because of an urgent audit." Which control is the recommended response?

○ A. Reply to the email and ask the supplier to confirm the new account

○ B. Check that the email carries a valid DKIM signature, then make the change

○ C. Forward the email to a colleague and ask whether it looks genuine

○ D. Call the supplier on a phone number taken from the company's own records, not from the email, before changing anything

13. An email's headers show the envelope sender MAIL FROM: billing@cheap-mailer.net with SPF passing for cheap-mailer.net, while the visible From: line reads "Jane Doe, CEO" <jane.doe@victim-corporation.com>. Why did SPF not catch this, and which control closes the gap?

○ A. The SPF record for cheap-mailer.net is too loose; making it stricter would stop the message

○ B. SPF checks only the envelope sender, which really was cheap-mailer.net; a DMARC policy on victim-corporation.com requires the authenticated domain to match the visible From: domain

○ C. SPF only works on encrypted connections; requiring STARTTLS between mail servers would stop the message

○ D. SPF checks the message body rather than the headers; adding DKIM would make it check the From: line instead

14. In the July 2020 Twitter incident, the targeted employees had one-time-password MFA, yet the attackers still signed in to internal admin tools. What explains this, and which change would have stopped it?

○ A. The codes were too short; longer one-time codes would have prevented reuse

○ B. The employees had switched MFA off; enforcing MFA for everyone would have stopped it

○ C. The fake VPN portal collected each code as it was typed and replayed it to the real site before it expired; origin-bound FIDO2 keys would have refused to sign for the fake domain

○ D. The attackers had broken the one-time-password algorithm; switching to SMS codes would have stopped it

15. A phishing email links to a page that was harmless when the message was delivered at 9:00, but the attacker switches it to a password-harvesting form at 11:00. Which secure email gateway feature is designed for exactly this?

○ A. Attachment sandboxing

○ B. DMARC enforcement

○ C. A banner marking messages from outside the organisation

○ D. URL rewriting that re-checks the link each time it is clicked

16. A company runs DMARC at p=reject, a secure email gateway, and annual awareness training. A finance employee still wires millions to criminals after an email, sent from the real but taken-over mailbox of a known business partner, asks for an urgent change of bank details. Which assessment of the company's controls is most accurate?

○ A. The email controls did what they were built to do, because the message really did come from the partner's domain; the missing layer was a process control requiring out-of-band verification of any payment change

○ B. DMARC failed and should be relaxed from p=reject to p=quarantine so suspicious mail is kept for review

○ C. The gateway should have blocked the message, since an email with no link or attachment is itself a sign of fraud

○ D. The controls were complete; the fault lies only with the employee, and more frequent training would have been enough

17. An organisation that has never published DMARC wants to stop attackers spoofing its domain. The security lead proposes publishing p=reject on day one. Why is the usual rollout to begin at p=none?

- ○ A. A domain may only publish p=reject after it has been registered for a full year
- ○ B. At p=none the domain receives reports on every service sending as it, so legitimate third-party senders such as payroll or newsletter platforms can be authenticated before enforcement starts refusing their mail
- ○ C. p=none blocks spoofed mail more gently by adding a warning banner instead of deleting it
- ○ D. p=reject would also block the mail the organisation receives from other domains

18. After a vishing campaign in which callers posed as IT support and talked staff into "updating VPN settings" on a lookalike portal, a company wants layered controls that each break a different step of the attack. Which set does this best?

- ○ A. Longer passwords, quarterly password changes, and a company password manager
- ○ B. A stricter spam filter, DMARC at p=reject, and attachment sandboxing
- ○ C. A rule that IT never asks for credentials by phone, with staff calling back on the published helpdesk number; FIDO2 keys for VPN and admin sign-in; and admin tools limited to the few people who need them
- ○ D. A yearly awareness video and phishing posters in every office